

Automating Windows Firewall Blocks via Wazuh Active Response for RDP Attackers

1- Blocking RDP brute force attacks in WAZUH, and incident response automation.

A- Brute force attack

Brute force attack is when an attacker tries to access the RDP (Remote Desktop Protocol) repeatedly with the wrong username and password.

Blocking RDP brute force attacks is an important step for security. Meaning, when WAZUH detects a suspicious pattern, like multiple failed RDP login attempts from the same IP, then WAZUH automatically uses active response to block that suspicious IP.

Step 1: automatically add the attacking IP to the Windows firewall?

A- define your active response commands

Do: open the configuration file in the WAZUH server or manager. , we go to Agent Management → Groups. For this lesson, we will use the Windows group, so click on it. At the end of this file, above the `</agent_config>` file, add this code block:

```
<!-- Brute Force Attack For attacks -->
<command>
  <name>netsh</name>
  <executable>netsh.exe</executable>
  <timeout_allowed>yes</timeout_allowed>
</command>
```

This means, we will define our active response commands, and we are using Windows `netsh.exe` (Network Shell), which is a built-in tool in Windows that manages firewall rules.

B- configure the active response

Configure the active response will inform the WAZUH manager that when an RDP attack is detected, it will execute the code block above (or command). To do it we will define this code block:

```
<active-response>
  <disabled>no</disabled>
  <command>netsh</command>
  <location>local</location>
  <rules_id>100921</rules_id>
  <timeout>900</timeout>
</active-response>
<!-- End of Brute Force Attacks -->
```

100921 is our RDP failed login ID, and 900 means that we will block the IP for 15 minutes.

Step 2: create the detection rule.

Do: Navigate to `/var/ossec/etc/rules` (`cd /var/ossec/etc/rules`), and open `local_rule.xml` file. At the end of that file, add this code block:

```
<group name="windows,rdp,bruteforce">
<rule id="100921" level="10" frequency="3" timeframe="120">
<if_matched_sid>60122</if_matched_sid>

<description>**RDP brute-force suspected: Multiple failed logins in a short period of time from IP:
$(win.eventdata.ipAddress)</description>
<options>no_full_log</options>
<mitre>
  <id>TA0006</id>
  <id>T1110</id>
</mitre>
</rule>
</group>
```

And save.

Now, go to your Windows agent, meaning the Windows machine or WAZUH agent, and create a script that will automatically add the attacker IP to the firewall.

NB: Make sure that windows machine is already connected to the wazuh server and forwarding logs

Do: Go to `C:\Program Files (x86)\ossec-agent\active-response\bin`. Here we will create the script.

So right-click and select Create.

NB: if It is not giving the option to create the file here, so we will go to Downloads, create the file there, and its extension should be `.cmd` (`block-rdp.cmd`). Edit it with this code:

```
@echo off
set IP=%1
netsh advfirewall firewall add rule name="Wazuh Block RDP %IP%" dir=in action=block protocol=TCP localport=3389
remoteip=%IP%
```

which is the script that will create the firewall rule.

Explanation of code

The name of the firewall rule will be `Wazuh Block RDP %IP%`.

`dir` means the direction of the traffic, whether it is inbound or outbound (here we have inbound).

The action it will perform is to block (`action=block`).

Protocol is TCP

The local port, which is RDP's default port is 3389,

This (`remoteip=%IP%`) means, the attacker IP will be blocked within the firewall.

Save it.

After this, the file we created in our Downloads folder, cut it and went back to the agent again (C:\Program Files (x86)→ossec-agent→active-response→bin) and paste it. Go to your WAZUH server, and restart (`sudo systemctl restart wazuh-manager`)

Step 3: Perform the attack.

Now I am going to machine 2 and accessing my WAZUH agent machine. Let us check the IP of our WAZUH machine. I will go back to the Windows agent. IP config. So our WAZUH Windows agent machine's IP is 10.150. Okay, again going to Windows machine 2. I will enter the IP. The username is on connect. And here I will perform failed login attempts. It has blocked it. Now we will go to our WAZUH dashboard and see if the alert was generated or not. So look, you can see that it generated an alert RDP brute force detected and the attacker's IP was 59.9. Let me show it to you. IP config. I am going to machine 2. So its IP is 59. Let's make this full screen here for a better view. You can see further information here. It is showing the machine name and the username of that machine, right? Now we will check if the connection is blocked on the firewall or not. I have now come to my WAZUH Windows agent. Type firewall here. Hit enter. Inbound rules. And here you can see that it has blocked the connection. Right click. Properties. Go to general. Scope and the attacker IP has been added automatically. It has blocked it., structure it very well